

GRC Intelligence Engine

From initiative intake to a sourced, auditor-ready governance package

A personal prototype exploring where technology GRC is heading: describe any initiative in plain language, and the engine returns the risks, controls, evidence, and framework mapping a senior GRC architect would draft — every line traceable to a curated library.

Built independently as personal R&D. Uses only public frameworks and synthetic examples; contains no confidential or employer-proprietary information.

Part 1 · Case Study

The problem

Every new initiative in a technology environment — onboarding a payment vendor, deploying an AI tool, recovering a site knocked offline by a storm — carries risk, control, and evidence implications that someone has to scope. Today that first-draft scoping is slow, depends heavily on which analyst picks it up, and lives in spreadsheets and institutional memory. Governance arrives after decisions are made rather than alongside them, and two analysts rarely produce the same answer.

The approach

I built a working engine that turns a plain-language initiative description into a complete first-draft governance package:

- a risk register rated for both inherent and target-residual exposure;
- the controls that mitigate each risk, with suggested owners and cadence;
- an implementation checklist and audit testing procedure for every control;
- the frameworks implicated — SOX ITGC, PCI DSS 4.0, NIST CSF 2.0, ISO 27001/22301, NIST AI RMF, and more;
- and an exportable executive summary suitable for leadership or an auditor.

Every line traces to a curated knowledge library — an inspectable graph of risks, controls, frameworks, and evidence — rather than being generated on the fly. An optional AI layer adds nuance specific to the initiative on top of that grounded baseline.

Key design decisions

Curated library, not a model. The defensible asset is the knowledge graph — versioned, owned, improving with use — not a prompt. Anyone can wrap an LLM; the curation is the moat and the source of auditability.

Assistive, never authoritative. Output is an accelerated draft a qualified practitioner owns — explicitly not an audit opinion, a QSA assessment, or legal advice. That boundary is both an ethical line and what makes the tool viable.

Deterministic core, AI at the edge. The risk-and-control logic is reproducible and testable; the model only adds initiative-specific commentary. Governance cannot rest on a black box.

Inspectable by design. Every risk and control opens to its source entry — statement, owner, the evidence an auditor expects. Unsourced output has no place in GRC.

Conservative by default. The residual model is calibrated to be credible rather than flattering: strong controls on a severe risk leave meaningful residual, not zero.

Deliberately scoped. It assesses preparedness, not incident response — a boundary chosen on purpose rather than a gap.

Outcome & value

- **Speed.** First-draft scoping moves from days to minutes.
- **Consistency.** The same initiative yields the same package regardless of who runs it.
- **Recall that does not fatigue.** On a disaster scenario it surfaced PCI DSS 12.10.1 — the kind of cross-domain obligation a tired analyst misses at 5 p.m.
- **Defensibility.** Every output is sourced, and the human stays accountable.

Positioned as the intake layer of a connected GRC ecosystem: describe an initiative once, and the governance scaffolding assembles itself, ready to flow into the systems of record.

Built with React and a curated knowledge graph (7 initiative archetypes, 21 risks, 31 controls across 12+ frameworks), with an optional Anthropic API layer. Next step: wire the intake layer to ServiceNow and OneTrust so a generated package becomes live records.

Part 2 · Design Decisions & Tradeoffs

The prototype's value is less in the code than in the choices behind it. Each below is a deliberate tradeoff, not a default.

Decision	Alternative considered	Why I chose it	What I traded away
Curated knowledge library as the core asset	Prompt an LLM to generate risks and controls per request	Moat, consistency, and auditability live in curated data, not a prompt; output can be inspected and defended	Upfront curation cost; the library must be maintained or it goes stale
Deterministic engine; AI only at the edge	Generative-first — let the model do all of it	The same initiative must yield the same governance; a black box cannot be audited or tested	Less "magic"; classification is keyword-based and brittle at the margins (a known, accepted prototype limit)
Assistive draft, human accountable	Position as an automated assessment or "AI auditor"	Keeps the tool on the right side of professional-opinion and liability lines; matches how GRC assigns accountability	Cannot make the stronger "automation replaces the analyst" claim
Inspectable output (transparency drawer)	Present conclusions only	Trust and auditability — every line traces to its source; reviewers verify rather than believe	Build effort; deliberately exposes the library's contents
Residual model as tunable data	Hard-code a scoring formula	Risk appetite is organizational; weights live as data so a practitioner recalibrates without touching logic	Requires explaining the model rather than hiding it — which invites debate on the numbers (the point)
Conservative residual calibration	Show maximal risk reduction	Credibility with a skeptical GRC audience — controls reduce risk, they do not erase it	A less impressive headline number
Preparedness scope, not incident response	Cover the full DR lifecycle	A focused tool that does one thing well beats one that does two shallowly; the output shape fits assessment, not a live runbook	Does not serve the mid-incident use case (a separate mode if ever pursued)

Failure modes I designed against

- **Stale library.** The asset decays without ownership — mitigated by treating the library as a maintained, versioned artifact.

- **Over-trust.** Users treating a draft as an answer — mitigated by the assistive framing and an at-output liability banner.
- **Flattering math.** Residual that erases risk — mitigated by conservative, transparent calibration.
- **Scope creep.** The pull to bolt on incident response, integrations, and deployment before the core is validated — resisted deliberately.

What I deliberately did not build (yet)

- Deployment and UAT scaffolding — premature before a sponsor and a pilot exist.
- Live incident-response runbooks — a different product mode.
- ServiceNow / OneTrust integrations — the right next step, but only once the concept is validated.

Part 3 · Demo Script & Talk Track

A five-minute live walkthrough. The art of the possible is witnessed, not explained — so this is built to be shown, not narrated from slides.

Three claims to anchor on

- **Speed.** Days to minutes for a first-draft package.
- **Consistency.** Analyst-dependent today; identical every time here.
- **Recall.** Surfaces cross-domain obligations a tired human misses.

The five-minute arc

Time	What you do	What you say
0:00	Set the scene (spoken)	When a new initiative lands — a payment vendor, an AI tool, a store knocked offline by a storm — someone has to scope its governance implications. Today that takes days, depends on who picks it up, and lives in spreadsheets. Watch what minutes looks like.
0:30	Type a real, recognizable initiative; click Generate	I'll describe something real, in plain English — the way a business partner would tell me about it. No forms, no taxonomy to learn.
1:30	Walk the register (inherent to residual), control matrix, checklist, testing procedures	Here's the package: every risk rated for inherent and residual exposure, the controls that move it, who owns them, and how to implement and test each one — in seconds.
3:00	Open the transparency drawer on a risk and a control	This is the part that matters for our world: it's not a model guessing. Every line traces to a curated library — the statement, the owner, the evidence an auditor expects. The human stays accountable; this accelerates judgment, it doesn't replace it.
4:00	Hit Export	And here's the summary I'd hand to leadership or drop straight into an audit response.
4:30	Cast the vision (spoken)	Now picture this as the intake layer of our connected ecosystem — wired to ServiceNow and OneTrust. Describe an initiative once, and the governance scaffolding writes itself into the systems of record.

For a retail or convenience-store audience, run the disaster scenario live. It is visceral, and the honest residual story — severe risks stay elevated even with controls in place — lands as credible rather than naive.

Questions to expect (and crisp answers)

Likely question	Crisp answer
Isn't this just ChatGPT?	No — the core is a curated, deterministic library, not a prompt. The model only adds nuance at the edge. That is what makes it consistent and auditable.

Likely question	Crisp answer
How do you keep it from going stale?	The library is a maintained, versioned artifact with named ownership — the same discipline we apply to a control catalog. Staleness is a process risk, managed like one.
Who is accountable for the output?	Always a qualified human. It is an assistive draft, explicitly not an audit or QSA opinion. The accountability model is unchanged; only the speed changes.
What is the failure mode?	Over-trust and library drift. I designed against both — at-output liability framing for the first, versioned ownership for the second.
What would you build next?	Integrations to the systems of record so a generated package becomes live records — and adoption metrics, because past a point the work is adoption, not design.
What did you deliberately not build?	Deployment and incident-response runbooks. A focused tool that does intake well beats a sprawling one. Scope discipline is part of the design.

Tailoring for the room

- **For a hiring manager:** lead with the design decisions and the "intake layer of an ecosystem" vision — frame it as how you'd approach building and leading, not as a tooling demo.
- **For a fellow practitioner:** lead with the transparency drawer and the residual model — they'll want to kick the tires on rigor.
- **Hold to five minutes.** Resist narrating every field. The restraint signals seniority.

This prototype reflects how I think about governance: as a connected system, engineered for traceability, where technology accelerates accountable human judgment rather than replacing it.
